# MR Risk Assistant

Putting review effort where the risk is

TEAM018 | M Mahadev | 2025mb26043
MBA ZG583 Management of AI Products

# The problem and the stakes

- Every MR gets about the same review. Risk is not evenly spread.
- The expensive mistakes are often small: a key in a config file, `privileged: true`, `0.0.0.0/0`, a payment fix with no tests.
- Big but harmless MRs (UI, translations) take the senior attention instead.

# User and workflow

- Tech lead / reviewer with 15-30 open MRs, working oldest-first.
- Decision: *how much review does this MR need, and from whom?*
- Secondary: engineering manager, security and platform teams.

# Why AI, and why not just rules

- Size rule on my sample: caught 1 of 11 problem MRs, 4 of 5 flags were false alarms.
- Risk is a combination of signals, and the weights depend on the codebase. That's a learning problem.
- LLM for the explanation only. Hard rules for secrets and unsafe settings. The model can't overrule them.

# Product concept and MVP scope

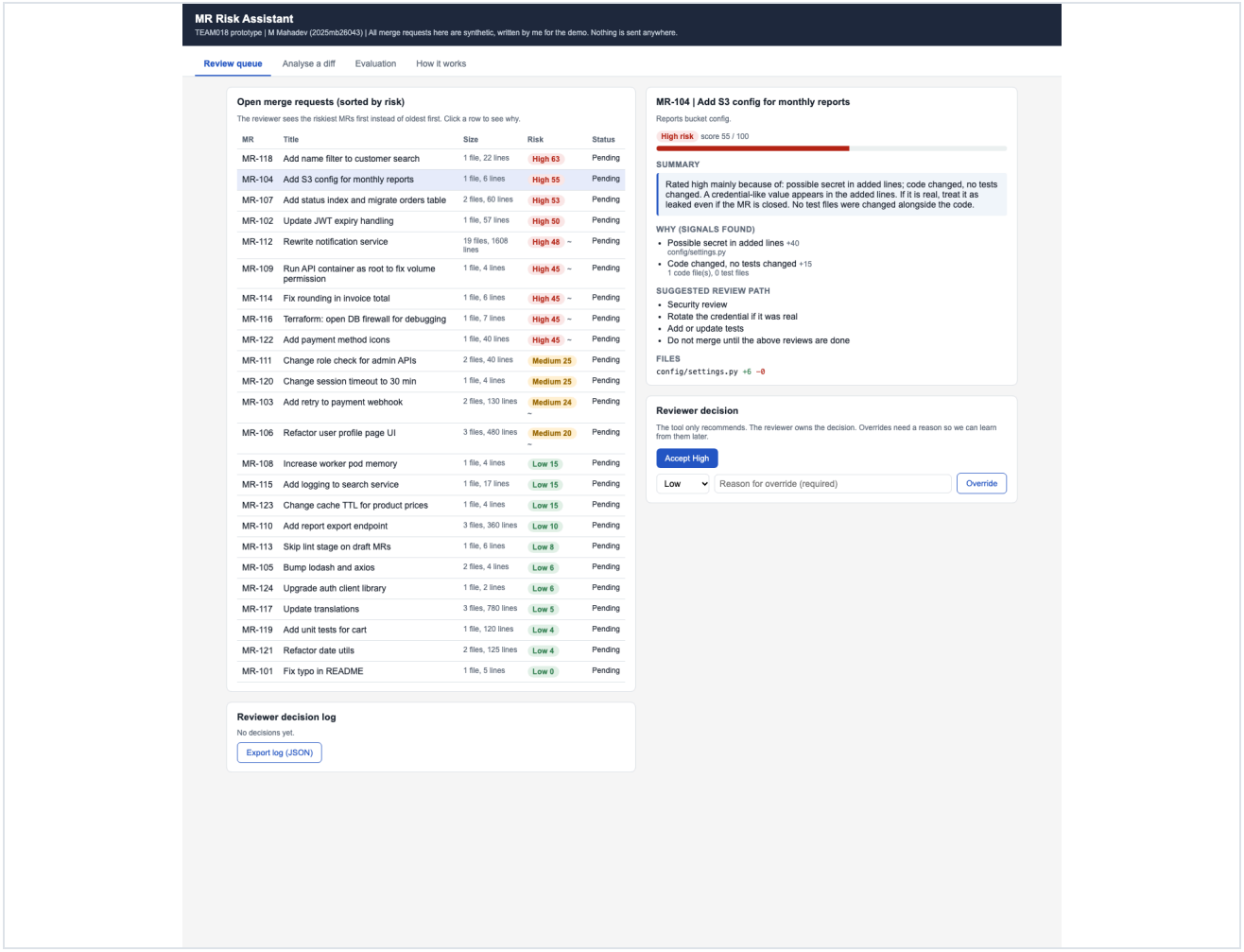
- Score + band + reasons + suggested review path + accept/override.
- MVP = rules + existing scanners + override log + risk-sorted queue.
- Out of scope: blocking merges, auto-approve, author scoring.

# Key PM decisions

- Build vs buy: reuse scanners, LLM via API (or self-hosted), **build the judgment layer**.
- RICE: secret detection first, learned model later (data confidence is low).
- Roadmap with proof gates: prototype, shadow, advisory, ML + LLM, scale.

# Prototype walkthrough (live demo)

1. Queue sorted by risk
2. MR-104: secret, hard rule, High despite 6 lines
3. MR-114: borderline, uncertainty warning
4. MR-122: false alarm, override with reason, override rate updates
5. Paste a diff
6. Evaluation tab, including the 3 misses



# Metrics and economics

- Pilot metrics: recall of problem MRs, share of queue flagged (< 30%), override rate (< 25%), usefulness rating.
- Economics: review time roughly evens out (less on Low, more on High).
- **The case is risk reduction:** one prevented incident a month (~₹1.5 lakh) vs ~₹10-20k running cost. All numbers are assumptions until the pilot.

# Risks and controls

- False safety from "Low": advisory only, uncertain band, "not analysed" never shown as Low.
- Alert fatigue: queue-share guardrail.
- People scoring: no author features, no per-person views.
- Code privacy: rules run in-house, LLM only if approved.
- Launch blockers: missed secret in shadow mode, >30% flagged, scores used on individuals.

# Recommendation

**Pilot.** One team, 2-3 repos, 2 weeks shadow + 6 weeks advisory. Go further only if the gates hold. Stop if reviewers ignore it or it floods them. What the prototype does not prove: real accuracy, LLM quality, long-term trust.